République du Cameroun
Paix-Travail-Patrie
****
Ministère de l'Enseignement Supérieur
****
Université de Garoua
****
Faculté des Sciences
****
Division des Affaires Académiques, de la Scolarité et de la Recherche

Republic of Cameroon
Peace-Work-Fatherland
****
Ministry of Higher Education
****
Université of Garoua
****
Faculté of Science
****
Division of Academic Affairs, Student's Admission and Research

TRAVAUX PRATIQUES ENCADRÉS

UE : Supervision, Analyse Forensique et Gestion des incidents

Étudiant	NEYAMBE GONG
Matricule	
Niveau	Master II

Année Académique : 2025-2026

TRAVAIL PRATIQUE DU CHAPITRE III

Ex. 3.1 — Écriture de règle Suricata

Règle Suricata

```
alert tcp 192.168.20.0/24 any -> any ![80,443,22] (
    msg:"REVERSE_SHELL Netcat nc -e /bin/bash depuis VLAN20";
    flow:established,to_server;
    content:"nc"; nocase;
    content:"/bin/bash"; nocase; distance:0;
    classtype:trojan-activity;
    metadata:mitre_technique T1059.004,
             mitre_tactic execution;
    sid:9000001;
    rev:1;
)
```

Ex. 3.2 — Analyse d'alerte EVE-JSON

Contexte : À partir d'une alerte EVE-JSON générée par Suricata sur un trafic contenant nc -e /bin/bash, on répond aux 4 questions de qualification.

(a) Attaque probable

Reverse shell via Netcat. L'attaquant exécute nc -e /bin/bash sur la machine victime pour lui faire initier une connexion sortante vers son serveur C2. Cette technique permet de contourner les pare-feux qui bloquent les connexions entrantes.

(b) TTP MITRE ATT&CK

- **Primaire :** T1059.004 — Command & Scripting Interpreter : Unix Shell (Tactic : Execution - TA0002)
- **Secondaire :** T1071.001 — Application Layer Protocol : Web (si C2 encapsulé en HTTP)
- **Possible :** T1048 — Exfiltration Over Alternative Protocol (si exfiltration de données)

(c) Trafic bloqué ou alerté ?

Réponse : Avec l'action alert, le trafic est uniquement alerté — il n'est PAS bloqué. Suricata est en mode NIDS (passif/TAP). Pour bloquer activement, il faudrait :

- Utiliser l'action drop (mode IPS inline)
- Déployer Suricata en mode inline (bridge ou NFQueue sous Linux)

(d) 3 étapes de qualification N1

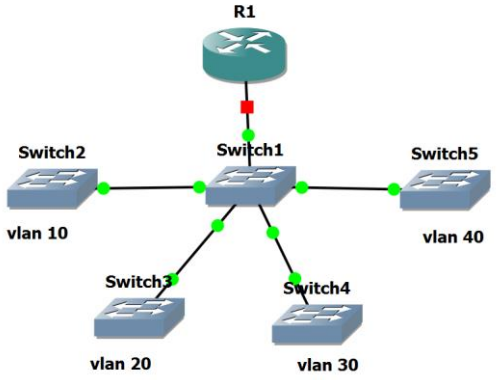
1. Vérifier la légitimité : Confirmer que l'IP source (VLAN 20) ne correspond pas à un outil d'administration autorisé (test de pénétration interne, scanner de vulnérabilités). Consulter la CMDB(configuration management and data base) et les tickets ouverts.

2. Corréler dans le SIEM : Rechercher d'autres alertes associées à la même IP source/destination : connexions sortantes inhabituelles, tentatives d'escalade de privilèges (T1068), mouvement latéral (T1021). Vérifier les logs système (HIDS).

3. Escalader en N2 si confirmé : Isoler la machine compromise du réseau (quarantaine VLAN), collecter les artefacts (capture pcap, logs Suricata EVE-JSON, mémoire vive si possible), ouvrir un ticket d'incident P1 et notifier le SOC N2.

Ex. 3.3 — Plan de déploiement IDS pour LiZbiZ-SIS

Plan IDS/HIDS complet couvrant la localisation des capteurs, le mode de déploiement, le type de sonde, les règles prioritaires et les métriques de suivi.



Localisation et configuration des capteurs

Emplacement	Type	Mode	Rôle
Cœur de réseau (agrégation)	NIDS (Suricata)	TAP (passif)	Visibilité globale inter-VLAN, détection sans impact réseau
DMZ (serveurs exposés)	NIDS (Suricata)	Inline / IPS	Blocage actif des attaques entrantes (action drop)
VLAN 20 (utilisateurs)	NIDS (Suricata)	TAP (passif)	Détection mouvements latéraux et reverse shells
Serveurs critiques (SIS)	HIDS (Wazuh)	Agent local	Intégrité fichiers (FIM), logs système, rootkit detection
Postes sensibles / admins	EDR	Agent local	Comportement processus, mémoire, lateral movement
Frontière Internet / pare-feu	NIDS (Suricata)	Inline / IPS	Filtrage périmétrique, blocage C2 et scans entrants

Règles prioritaires à activer

#	TTP / Catégorie	Description
1	T1059 — Reverse shells	Signatures nc, bash, python, perl avec redirection I/O
2	T1046 — Scans de ports	Détection nmap, masscan, unicornscan (SYN flood, timing)
3	T1110 — Brute-force	SSH, RDP, HTTP Basic Auth — seuil > 10 tentatives/min
4	T1048.003 — Exfiltration DNS	Requêtes DNS anormalement longues ou à haute fréquence
5	T1190 — Exploitation web	Injections SQL, XSS, exploitation CVE sur services exposés
6	LOLBins	Utilisation anormale de wget, curl, certutil, bitsadmin

Métriques de suivi

Métrique	Objectif / Description
Taux de faux positifs (FPR)	Objectif < 5% — ajuster les seuils et règles régulièrement
MTTD — Mean Time To Detect	Temps moyen entre l'attaque et la première alerte
Nombre d'alertes critiques	Suivi par heure/jour — détecter les pics anormaux
Couverture MITRE ATT&CK	% de techniques couvertes par les règles actives
Disponibilité des capteurs	Uptime cible > 99,9% — supervision via Zabbix
Temps de traitement N1/N2	MTTR (Mean Time To Respond) — SLA interne à respecter

TRAVAIL PRATIQUE DU CHAPITRE IV

Ex. 4.1 — Qualification juridique.

Selon la loi 2010/012 :

- **Accès frauduleux à un système d'information (Art. 62)**

- **Maintien frauduleux dans un système (Art. 63)**

- **Atteinte à l'intégrité d'un système ou de données (Art. 64–66)**

- **Interception illégale de communications (Art. 67)**

Pour prouver l'incident il faut collecter les logs SIEM et délai de notification n'est pas déterminée par la loi 2010/012.

Ex. 4.2 — Chaîne de custody

PV DE SAISIE COMPLET :

- **Contexte :** suspection
- **Pièce :** laptop
- **Date et heure de collecte :** 29/04/2026, 12 :23AM
- **Collecteur :** NEYAMBE GONG
- **Méthode :** confiscation du laptop
- **Conservation du laptop :** Coffre-fort scellé dans salle serveur

Ex. 4.3 — Politique de rétention

TABLEAU DE RÉTENTION UNIFIÉ

Catégorie de données	Loi Cameroun 2024/017	Convention Malabo (UA)	RGPD (Référentiels)	Durée retenue
Données client	**Finalité +décret APDP**	**Proportionnalité**	**Finalité 3 ans max**	**3 ans**
Données contractuelles	**Finalité +décret APDP**	**Limitation finalité**	**5-6 ans**	**6 ans post-constrat**

Données comptables/fiscales	**Obligations fiscales cm**	**-**	**7-10 ans**	**10 ans**
Logs cybersécurité	**Loi 2010/012**	**Cybersécurité**	**1 ans minimum**	**1-2 ans**
Données sensibles	**Autorisation APDP prealableprotection renforcé**	**protection renforcé**	**Durée minimale stricte**	**Durée minimale+ autorisation**
Post-finalité accomplies	**Suppression requise**	**Suppression requise**	**Suppression immédiate**	**Suppression Sous 30 jours**
Données cloud	**--**	**-**	**Garanties adéquates**	**Contrat hebergergeur+durée du traitement**